

HO/01/IT/2025-26/88

Date:22.05.2025

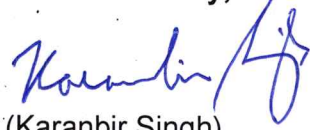
Circular to all Branches & Offices
Issued by Information Technology Department

Re: Policy for Outsourcing of Information Technology Services (Version 1.0) of the Bank

Branches & Offices are hereby informed that the Policy for Outsourcing of Information Technology Services (Version 1.0) of the Bank of the Bank has been approved by the Hon'ble Board of Directors through agenda item no.10 in its meeting no.01(01/2025) dated 07.05.2025. The policy will come into force with immediate effect & validity of the policy is for next three years from the date of approval. The approved policy for Outsourcing of Information Technology Services is attached here with this circular.

Kindly bring the content of this policy in the notice of all staff members of the Branches/Offices.

Yours faithfully,



(Karanbir Singh)
General Manager

Enclosure: As above

Policy for Outsourcing of Information Technology Services

(Version – 1.0)

**Uttar Pradesh Gramin Bank
Information Technology Department
Head Office, Lucknow**

Uttar Pradesh Gramin Bank

Policy for Outsourcing of Information Technology Services: Version 1.0

Document Information

Document Name	Policy for Outsourcing of Information Technology Services
Document Owner	Information Technology Department
Document Version No.	1.0
Document Version Date	
Prepared By	Information Technology Department
Reviewed By	
Approved By	

Version History

Version No.	Version Date	Prepared By
1.0		

Current Version Reviewed by

Version No.	Designation	Department
1.0		

Distribution List

Version No.	Name	Designation	Department
1.0	N.A.	All Departmental Heads	All Departments, Controlling Offices and Branches

Index

Sr. No.	Particular	Page No.
1.	Introduction	04
2.	Scope of Policy.....	04
3.	Definition and Coverage of Outsourcing.....	04
3.1	Inclusive Services under Outsourcing	05
3.2	Excluding Services under Outsourcing.....	05-06
4.	Roles and Responsibilities.....	06-07
5.	Regulatory and Supervisory requirements	07-09
6.	Grievance Redressal Mechanism.....	08-09
7.	Outsourcing Agreement	9-11
8.	Risk Management Framework	11-12
9.	Monitoring and Control of Outsourced Activities.....	12-13
10.	Exit Strategy	13
11.	Confidentiality and Security.....	13-14
12.	Review of the Policy	14
13.	Appendix – I (Usage of Cloud Computing Services).....	15 -17
14.	Appendix – II Outsourcing of Security Operations Centre.....	18

1. Introduction:

The rapid expansion and the growth in the banking industry, centralization, technological transformation, the need to focus on core services and introduction of new services have influenced the need of outsourcing in the banks. Apart from cost savings and accessing specialist expertise not available internally, for achieving strategic aims and efficient delivery mechanisms, outsourcing remains preferred destination for enabling perfection in selective business processes. However, this outsourcing has resulted the banks being exposed to various risks.

Recognizing the need for outsourcing some of the selected activities by the banks, Reserve Bank of India has put in place comprehensive guidelines for addressing the risks that the banks would be exposed to on account of engaging any outsourcing agency.

The outsourcing policy of our bank based on RBI guidelines has been devised to ensure safeguarding the interest of the bank and the customers by adopting sound and responsive management practices through due diligence and management of risks arising from outsourcing activities.

The guidelines are applicable to outsourcing arrangements entered into by the bank with the service provider/s located in India.

2. Scope of Policy

This policy will be specific for the areas under Information Technology to cater to the banks' requirement. The RBI has come out with its guidelines vide their notification no. RBI/2023-24/102 DoS.CO.CSIT/SEC.1/31.01.015/2023-24 April 10, 2023 as Master Direction on Outsourcing of Information Technology Services. We have referred to this guideline to frame Outsourcing Policy for our bank.

- RBI/2022-23/xx DoS.CO.CSIT/SEC.xx/31.01.015/2022-23 dated June 23, 2022
- RBI/2023-24/102 DoS.CO.CSIT/SEC.1/31.01.015/2023-24 dated April 10, 2023

The policy incorporates the criteria for selection of the activities that may or may not be outsourced, risks arising out of outsourcing, management of these risks, delegation of powers, etc. The policy shall apply to activities outsourced to service providers and mutatis mutandis to activities subcontracted by the service providers.

This policy shall apply to Material Outsourcing of Information Technology ('IT') Services arrangements as defined in the policy.

3. Definition and Coverage of Outsourcing

For the purpose of this policy, Outsourcing shall refer to bank's use of a third party (either an affiliated entity within a corporate group or an entity that is external to the corporate group) to perform activities on a continuing basis (including agreements for a limited period), that would normally be undertaken by the bank, now or in the future.

"Material Outsourcing of IT Services" are those which: a) if disrupted or compromised shall have the potential to significantly impact the Bank's business operations; or b) may have material impact on the Bank's customers in the event of any unauthorised access, loss, or theft of customer information.

It shall further cover the criteria for selection of such activities as well as service providers, parameters for defining material outsourcing based on the broad criteria, delegation of authority depending on risk and materiality, disaster recovery and business continuity plans, systems to monitor and review the operations of these activities and termination processes and exit strategies, including business continuity in the event of a third-party service provider exiting the outsourcing arrangement.

W CL

3.1 Outsourcing of IT Services shall include outsourcing of the following activities:

- a) IT infrastructure management, maintenance and support (hardware, software or firmware);
- b) Network and security solutions, maintenance (hardware, software or firmware);
- c) Application Development, Maintenance and Testing; Application Service Providers (ASPs) including ATM Switch ASPs;
- d) Services and operations related to Data Centres;
- e) Cloud Computing Services;
- f) Managed Security Services; and
- g) Management of IT infrastructure and technology services associated with payment system ecosystem.

Service provider means the provider of IT or IT enabled services including entities related to the Bank or those which belong to the same group or conglomerate to which the Bank belongs.

Undermentioned list of services/activities provides an indicative (but not exhaustive) which are not considered under "Outsourcing of IT Services" for the purpose of this policy and Vendors / Entities who are not considered as Third-Party Service Provider (TPSP) for the purpose of this policy.

3.2 Services not considered under Outsourcing of IT Services

A. Services / Activities not considered under "Outsourcing of IT Services" for the purpose of this policy (an indicative but not exhaustive list)

- i. Corporate Internet Banking services obtained by regulated entities as corporate customers/ sub members of another regulated entity
- ii. External audit such as Vulnerability Assessment/ Penetration Testing (VA/PT), Information Systems Audit, security review
- iii. SMS gateways (Bulk SMS service providers)
- iv. Procurement of IT hardware/ appliances
- v. Acquisition of IT software/ product/ application (like CBS, database, security solutions, etc.) on a license or subscription basis and any enhancements made to such licensed third-party application by its vendor (as upgrades) or on specific change request made by the Bank.
- vi. Any maintenance service (including security patches, bug fixes) for IT Infra or licensed products, provided by the Original Equipment Manufacturer (OEM) themselves, in order to ensure continued usage of the same by the Bank.
- vii. Applications provided by financial sector regulators or institutions like CCIL, NSE, BSE, etc.
- viii. Platforms provided by entities like Reuters, Bloomberg, SWIFT, etc.
- ix. Any other off the shelf products (like anti-virus software, email solution, etc.) subscribed to by the regulated entity wherein only a license is procured with no/ minimal customisation
- x. Services obtained by a Bank as a sub-member of a Centralised Payment Systems (CPS) from another Bank.
- xi. Business Correspondent (BC) services, payroll processing, statement printing

B. Vendors / Entities who are not considered as Third-Party Service Provider for the purpose of this policy (an indicative but not exhaustive list)

- i. Vendors providing business services using IT. Example – BCs
- ii. Payment System Operators authorised by the Reserve Bank of India under the Payment and Settlement Systems Act, 2007 for setting up and operating Payment Systems in India
- iii. Partnership based Fintech firms such as those providing co-branded applications, service, products (would be considered under outsourcing of financial services)

- iv. Services of Fintech firms for data retrieval, data validation and verification services such as (list is not exhaustive):
 - a. Bank statement analysis
 - b. GST returns analysis
 - c. Fetching of vehicle information
 - d. Digital document execution
 - e. Data entry and Call centre services
- v. Telecom Service Providers from whom leased lines or other similar kind of infrastructure are availed and used for transmission of the data
- vi. Security/ Audit Consultants appointed for certification/ audit/ VA-PT related to IT infra/ IT services/ Information Security services in their role as independent third-party auditor/ consultant/ lead implementer.

Advantages of Outsourcing:

Banks are increasingly using outsourcing as a means of both reducing costs and accessing specialist expertise, not available internally and achieving strategic aims.

4. Roles and Responsibilities:

The Senior Management of the Bank shall, inter alia, be responsible for:

- a) Formulating IT outsourcing policies and procedures, evaluating the risks and materiality of all existing and prospective IT outsourcing arrangements based on the framework commensurate with the complexity, nature and scope, in line with the enterprise-wide risk management of the organisation approved by the Board and its implementation;
- b) Prior evaluation of prospective IT outsourcing arrangements and periodic evaluation of the existing outsourcing arrangements covering the performance review, criticality and associated risks of all such arrangements based on the policy approved by the Board;
- c) Identifying IT outsourcing risks as they arise, monitoring, mitigating, managing and reporting of such risks to the Board/ Board Committee in a timely manner;
- d) Ensuring that suitable business continuity plans based on realistic and probable disruptive scenarios, including exit of any third-party service provider, are in place and tested periodically;
- e) Ensuring (i) effective oversight over third party for data confidentiality and (ii) appropriate redressal of customer grievances in a timely manner;
- f) Ensuring an independent review and audit on a periodic basis for compliance with the legislations, regulations, Board-approved policy and performance standards and reporting the same to Board/ Board Committee; and
- g) Creating essential capacity with required skillsets within the organisation for proper oversight of outsourced activities.

As we are being supervised by RRB Cell of Sponsored Bank and being operationalised/managed by BOB RRB Data Centre regarding all technical functionalities and towards finalization of outsourcing/vendors for technological aspects for the bank requires broad technical expertise/exposures including cost efficiency (managed through sharing of cost among RRBs), most of the outsourcing/vendor finalization task is finalised by sponsored bank (RRB Cell/BOB RRB DC) in accordance with their policies. Regarding such services/products/ procurements, appropriate committee at sponsored bank takes decision, accords in principle approval by competent authority, arrange RFPs activities for common (along with BOB requirements) / specific (for RRBs)

Handwritten signature/initials

requirements for our Bank followed by concurrence of respective RRBs and approval of Hon'ble Board of respective/all RRBs.

At Bank level initiation towards getting any technical services through outsourcing will be taken by the IT Department, Head Office. After approval from the competent authority finalisation of vendor/procurement procedure will be processed through procurement committee of the Bank.

Role of IT Function

The responsibilities of the IT Function of the Bank shall, inter alia, include:

- a) assisting the Senior Management in identifying, measuring, monitoring, mitigating and managing the level of IT outsourcing risk in the organization through RCSA/ORMC;
- b) ensuring that a central database of all IT outsourcing arrangements is maintained and is accessible for review by Board, Senior Management, Auditors and Supervisors;
- c) effectively monitor and supervise the outsourced activity to ensure that the service providers meet the laid down performance standards and provide uninterrupted services, report to the Senior Management; co-ordinate periodic due diligence and highlight concerns, if any; and
- d) putting in place necessary documentation required for contractual agreements including service level management, monitoring of vendor operations, key risk indicators and classifying the vendors as per the determined risk.

5. Regulatory and Supervisory requirements

a) Outsourcing of any activity shall not diminish the Bank's obligations as also of its Board and Senior Management, who shall be ultimately responsible for the outsourced activity. Bank shall not engage an IT service provider that would result in reputation of Bank being compromised or weakened.

b) Notwithstanding whether the service provider is located in India or abroad, the Bank shall ensure that the outsourcing should neither impede nor interfere with the ability of the Bank to effectively oversee and manage its activities. Further, the Bank shall ensure that the outsourcing does not impede the RBI/NABARD in carrying out its supervisory functions and objectives.

c) The Bank shall ensure that the service provider, if not a group company, shall not be owned or controlled by any director, or key managerial personnel, or approver of the outsourcing arrangement of the Bank, or their relatives. The terms 'control', 'director', 'key managerial personnel', and 'relative' have the same meaning as assigned under the Companies Act, 2013 and the Rules framed thereunder from time to time. However, an exception to this requirement may be made with the approval of the Board/ Board level Committee, followed by appropriate disclosure, oversight and monitoring of such arrangements. The Board shall inter-alia ensure that there is no conflict of interest arising out of third-party engagements.

d) Additional requirements pertaining to usage of cloud computing services and outsourcing of Security Operations Center (SOC) services are outlined in Appendix I and Appendix II, respectively.

Comprehensive assessment of need for outsourcing and attendant risks

Bank shall evaluate the need for Outsourcing of IT Services based on comprehensive assessment of attendant benefits, risks and availability of commensurate processes to manage those risks. Bank will ensure to evaluate the need of outsourcing and risk aspect through RCSA/ORMC of the Bank.

Bank shall inter-alia consider:

- a) determining the need for outsourcing based on criticality of activity to be outsourced;
- b) determining expectations and outcome from outsourcing;
- c) determining success factors and cost-benefit analysis; and
- d) deciding the model for outsourcing.

[Handwritten signature]

Compliance with all applicable statutory and regulatory requirements

The Bank shall consider all relevant laws, regulations, rules, guidelines and conditions of approval, licensing or registration, when performing its due diligence in relation to outsourcing of IT services.

6. Grievance Redressal Mechanism

a) Bank shall have a robust grievance redressal mechanism that shall not be compromised in any manner on account of outsourcing, i.e., responsibility for redressal of customers' grievances related to outsourced services shall rest with the Bank.

b) Outsourcing arrangements shall not affect the rights of a customer against the Bank, including the ability of the customer to obtain redressal as applicable under relevant laws.

Inventory of Outsourced Services

Bank shall create an inventory of services provided by the service providers (including key entities involved in their supply chains). Further, the Bank shall map their dependency on third parties and periodically evaluate the information received from the service providers.

Evaluation and Engagement of Service Providers

a) In considering or renewing an Outsourcing of IT Services arrangement, appropriate due diligence shall be performed to assess the capability of the service provider to comply with obligations in the outsourcing agreement on an ongoing basis.

b) A risk-based approach shall be adopted in conducting such due diligence activities.

c) Due diligence shall take into consideration qualitative, quantitative, financial, operational, legal and reputational factors. Where possible, the Bank shall obtain independent reviews and market feedback on the service provider to supplement its own assessment.

d) Bank shall also consider, while evaluating the capability of the service provider, risks arising from concentration of outsourcing arrangements with a single or a few service provider/s.

Aspects to be considered

Due diligence shall involve evaluation of all available information, as applicable, about the service provider, including but not limited to:

a) past experience and demonstrated competence to implement and support the proposed IT activity over the contract period;

b) financial soundness and ability to service commitments even under adverse conditions;

c) business reputation and culture, compliance, complaints and outstanding or potential litigations;

d) conflict of interest, if any;

e) external factors like political, economic, social and legal environment of the jurisdiction in which the service provider operates and other events that may impact data security and service performance;

f) details of the technology, infrastructure stability, security and internal control, audit coverage, reporting and monitoring procedures, data backup arrangements, business continuity management and disaster recovery plan;

g) capability to identify and segregate Bank data;

h) quality of due diligence exercised by the service provider with respect to its employees and sub-contractors;

i) capability to comply with the regulatory and legal requirements of the Outsourcing of IT Services arrangement;

j) information/ cyber security risk assessment;

k) ensuring that appropriate controls, assurance requirements and possible contractual arrangements are in place to ensure data protection and Bank's access to the data which is processed, managed or stored by the service provider;

l) ability to effectively service all the customers while maintaining confidentiality, especially where a service provider has exposure to multiple entities; and

m) ability to enforce agreements and the rights available thereunder including those relating to aspects such as data storage, data protection and confidentiality.

7. Outsourcing Agreement:

The contract between the bank and the service provider should be a Legally Binding Agreement is to be carefully defined in written agreements. The terms and conditions governing the contract shall be carefully defined and vetted by the Bank's legal counsel for their legal effect and enforceability. The agreement shall be sufficiently flexible to allow the Bank to retain adequate control over the outsourced activity and the right to intervene with appropriate measures to meet legal and regulatory obligations.

Every such agreement should address the risks and risk mitigation strategies identified at the risk evaluation and due diligence stages. The agreement should be sufficiently flexible to allow the bank to retain an appropriate level of control over the outsourcing and the right to intervene with appropriate measures to meet legal and regulatory obligation. Bank shall ensure that their rights and obligations and those of each of their service providers are clearly defined and set out in a legally binding written agreement.

In principle, the provisions of the agreement should appropriately reckon the criticality of the outsourced task to the business of the Bank, the associated risks, and the strategies for mitigating or managing them.

The agreement shall also bring out the nature of legal relationship between the parties.

The basic ingredients of the agreement would be:

- The contract should clearly define what activities are going to be outsourced including appropriate service and performance standard.
- Effective access by the Bank to all data, books, records, information, logs, alerts and business premises relevant to the outsourced activity, available with the service provider
- Clause to claim compensation / penalty towards abrupt discontinuation of services will be properly defined in the Service Level Agreement (SLA); the bank should, wherever required, take a Performance guarantee and insist on inclusion of penalty clauses in the SLA;
- The contract should provide for continuous monitoring and assessment by the bank of the service provider, so that any necessary corrective measure can be taken immediately.
- The agreement should cover regarding type of material adverse events (e.g., data breaches, denial of service, service unavailability, etc.) and the incidents required to be reported by the service provider to Bank to enable us to take prompt risk mitigation measures and ensure compliance with statutory and regulatory guidelines;
- Compliance clause with the provisions of Information Technology Act, 2000, other applicable legal requirements and standards to protect the customer data.
- The deliverables, including Service-Level Agreements (SLAs) formalising performance criteria to measure the quality and quantity of service levels.
- Under outsourcing agreement there should be an information that "Pre Integrity pact has been executed along with IEM (Independent External Monitor) clause."
- Penal clause should be there if quality of the agreed upon services is not being delivered including interaction with the customers should not be inconsistent with the overall standards of the bank.
- Storage of data (as applicable for the Bank) only in India as per extant regulatory requirements.
- Clauses requiring the service provider to provide details of data (related to Bank and its customers) captured, processed and stored.
- Controls should be available to ensure customer data confidentiality of bank and its customers', and the service provider's liability in case of breach of security and leakage of such

information. Confidentiality of customer's information should be maintained even after the contract expires or gets terminated.

- Types of data/ information that the service provider (vendor) is permitted to share with Bank customer and / or any other party.
- Specifying the resolution process, events of default, indemnities, remedies, and recourse available to the respective parties
- Contingency plan(s) to ensure business continuity and testing requirements.
- Provision for Right to conduct audit of the service provider (including its sub-contractors, if any) by the Bank, whether by its internal or external auditors, or by agents appointed to act on its behalf, and to obtain copies of any audit or review reports and findings made about the service provider in conjunction with the services performed for the Bank.
- Right to seek information from the service provider about the third parties (in the supply chain) engaged by the former.
- Recognising the authority of regulators to perform inspections of the service provider and any of its sub-contractors. Adding clauses to allow RBI/NABARD or person(s) authorised by it to access the Bank's IT infrastructure, applications, data, documents, and other necessary information given to, stored or processed by the service provider and/ or its sub-contractors in relation and as applicable to the scope of the outsourcing arrangement.
- Including clauses making the service provider contractually liable for the performance and risk management practices of its subcontractors.
- Obligation of the service provider to comply with directions issued by the RBI/NABARD in relation to the activities outsourced to the service provider, through specific contractual terms and conditions specified by the Bank.
- Clauses requiring prior approval/ consent of the Bank for use of subcontractors by the service provider for all or part of an outsourced activity.
- Termination rights of the Bank, including the ability to orderly transfer the proposed IT-outsourcing arrangement to another service provider, if necessary or desirable
- Obligation of the service provider to co-operate with the relevant authorities in case of insolvency/ resolution of the Bank.
- Provision to consider skilled resources of service provider who provide core services as "essential personnel" so that a limited number of staff with back-up arrangements necessary to operate critical functions can work on-site during exigencies (including pandemic situations)
- Clause requiring suitable back-to-back arrangements between service providers and the OEMs.
- There must be a clause that "The service provider may not conduct any business on its behalf, which is inconsistent with the overall strategic goals of the bank for which their services has been outsourced".
- Clause requiring non-disclosure agreement with respect to information retained by the service provider.
- There should be a provision of regular meetings between vendors and bank to discuss cyber security related issues and developments and roles and responsibilities for vendor and bank should be defined in SLA in case of incident.
- Provision for penalties and legal action on vendor should be mentioned in case of breach of contract.
- Timeframe should be stipulated for implementing tools/applications/projects and ensuring uptime.
- Outsourcing Agreements should include clauses to recognise the right of RBI / NABARD to inspect banks documents, records, transactions, logs processed by the service provider, if any.

- There should be a clause in SLA with vendors to address grievances including system/technology issues.
- There should be a clause to ensure regulatory compliances by the vendors.
- SLA should be checked by the legal department or law officer for compliance.
- System access for doing financial transactions must be restricted to bank officials only.
- Provision for providing support for smooth transition/migration / upgradation from one system to another without hampering business continuity should be included in SLA.
- Contingency plans should be available to ensure business continuity.
- The outsourcing agreement should provide for the preservation of documents and data by the service provider in accordance with the legal regulatory obligations of the bank in this regard.
- All statutory obligations should be fulfilled by the vendors.

Service Level Agreements (SLAs) and performance metrics;

Bank while outsourcing any activity shall include SLAs in the outsourcing contracts to agree and establish accountability for performance expectations. SLAs must clearly formalize the performance criteria to measure the quality and quantity of service levels.

Bank shall develop the following towards establishing an effective oversight program:

- Document that defines the SLA program
- SLA monitoring process
- Recourse in case of non-performance
- Escalation process
- Dispute resolution process
- Conditions in which the contract may be terminated by either party.

For outsourced technology operations, specific metrics should be defined around the service availability, business continuity and transaction security, in order to measure services rendered by the external vendor organization. The SLA and performance metrics for outsourcing activities in technology operations should be in accordance with the latest Information Technology Operations /Security Policy of the Bank. Performance expectations, under both normal and contingency circumstances, should be defined. Provisions should be in place for timely and orderly intervention and rectification in the event of substandard performance by the service provider.

8. Risk Management Framework

Outsourcing of technical services exposes a bank to several risks which need to be evaluated and effectively managed & mitigated.

- (a) Bank will put in place a Risk Management framework for Outsourcing of IT Services that shall comprehensively deal with the processes and responsibilities for identification, measurement, mitigation, management, and reporting of risks associated with Outsourcing of IT Services arrangements. Regarding this, Bank's RCSA/ORMC in sync with BOB RRB Data Centre will evaluate and effectively arrange management.
- (b) The risk assessments carried out by the Bank & team at sponsor Bank's technical team shall be suitably documented with necessary approvals in line with the roles and responsibilities of the Board of Directors, Senior Management and IT Function. Such risk assessments shall be subject to internal and external quality assurance on a periodic basis as determined by the Board-approved policy.
- (c) Bank will be responsible for the confidentiality and integrity of data and information pertaining to the customers that is available to the service provider. To ensure the same, a

clause will be mentioned in SLA.

- (d) Access to data at Bank location / data center by service providers shall be on a need-to-know basis, with appropriate controls to prevent security breaches and/or data misuse.
- (e) Public confidence and customer trust in Bank is a prerequisite for their stability and reputation. Hence, Bank shall seek to ensure the preservation and protection of the security and confidentiality of customer information in the custody or possession of the service provider. Access to customer information by the staff of the service provider shall be on a need-to-know basis.
- (f) In the event of multiple service provider relationships where two or more service providers collaborate to deliver an end-to-end solution, the Bank remains responsible for understanding and monitoring the control environment of all service providers that have access to the Bank's data, systems, records or resources.
- (g) In instances where service provider acts as an outsourcing agent for multiple Bank, care shall be taken to build adequate safeguards so that there is no combining of information, documents, records and assets. This will be ensured through SLA.
- (h) The Bank shall ensure that cyber incidents are reported to the Bank by the service provider without undue delay, so that the incident is reported by the Bank to the RBI/NABARD within 6 hours of detection by the TPSP. This will be ensured through SLA.
- (i) The Bank/Data Centre shall review and monitor the control processes and security practices of the service provider to disclose security breaches. The Bank shall immediately notify RBI/NABARD in the event of breach of security and leakage of confidential customer-related information. In these eventualities, the Bank shall adhere to the extant instructions issued by RBI/NABARD from time to time on Incident Response and Recovery Management.
- (j) Concentration Risk: Bank shall effectively assess the impact of concentration risk posed by multiple outsourcings to the same service provider and/or the concentration risk posed by outsourcing critical or material functions to a limited number of service providers.

Business Continuity Plan and Disaster Recovery Plan

- a) Bank will require their service providers to develop and establish a robust framework for documenting, maintaining and testing Business Continuity Plan (BCP) and Disaster Recovery Plan (DRP) commensurate with the nature and scope of the outsourced activity as per extant instructions issued by RBI/NABARD from time to time on BCP/ DR requirements.
- b) In establishing a viable contingency plan, Bank will consider the availability of alternative service providers or the possibility of bringing the outsourced activity back in-house in an emergency, and the costs, time and resources that would be involved.
- c) In order to mitigate the risk of unexpected termination of the outsourcing agreement or insolvency/ liquidation of the service provider, Banks shall retain an appropriate level of control over their IT-outsourcing arrangement along with right to intervene, with appropriate measures to continue its business operations.
- d) Bank will ensure that service providers are able to isolate the Bank's information, documents and records and other assets. This is to ensure that, in adverse conditions or termination of the contract, all documents, record of transactions and information with the service provider and assets of the Bank can be removed from the possession of the service provider, or deleted, destroyed or rendered unusable.

9. Monitoring and Control of Outsourced Activities

Concerned department in coordination with IT Department will ensure to monitor and control its Outsourced IT activities. This shall include (as applicable to the scope of Outsourcing of IT Services) but not limited to monitoring the performance, uptime of the systems and resources, service availability, adherence to SLA requirements, incident response mechanism, etc.

The bank should, at least on an annual basis, review the financial and operational condition of the service provider to assess its ability to continue to meet its outsourcing obligations. Such due diligence reviews, which can be based on all available information about the service provider, should highlight any deterioration or breach in performance standards, confidentiality and security, and in business continuity preparedness.

While doing review of the performance of the service provider, extended quality of services must be added along with mentioned financial and operational conditions of the service provider.

Bank shall conduct regular audits (as applicable to the scope of Outsourcing of IT Services) of service providers (including subcontractors) with regard to the activity outsourced by it. Such audits may be conducted either by the Bank's internal auditors or external auditors appointed to act on the Bank's behalf.

While outsourcing various IT services, more than one Regulated Entity may be availing services from the same third-party service provider. In such scenarios, in lieu of conducting separate audits by individual Bank of the common service provider, they may adopt pooled (shared) audit. This allows the relevant Bank to either pool their audit resources or engage an independent third-party auditor to jointly audit a common service provider. However, in doing so, it shall be the responsibility of the Bank to ensure that the audit requirements related to their respective contract with the service provider are met effectively.

The audits shall assess the performance of the service provider, adequacy of the risk management practices adopted by the service provider, compliance with laws and regulations, etc. The frequency of the audit shall be determined based on the nature and extent of risk and impact to the Bank from the outsourcing arrangements. Reports on the monitoring and control activities shall be reviewed periodically by the Senior Management and in case of any adverse development, the same shall be put up to the Board for information.

In the event of termination of the outsourcing agreement for any reason in cases where the service provider deals with the customers of the Bank, the same shall be given due publicity by the Bank to ensure that the customers stop dealing with the concerned service provider.

Bank shall ensure that the service provider grants unrestricted and effective access to a) data related to the outsourced activities; b) the relevant business premises of the service provider; subject to appropriate security protocols, for the purpose of effective oversight use by the Bank, their auditors, regulators and other relevant Competent Authorities, as authorised under law.

10. Exit Strategy

Exit clauses will be mentioned in SLA with different scenarios. In documenting an exit strategy, the Bank shall, inter alia, identify alternative arrangements, which may include performing the activity by a different service provider or the Bank itself.

The bank shall ensure that the agreement has necessary clauses on safe removal/ destruction of data, hardware and all records (digital and physical), as applicable. However, service provider shall be legally obliged to cooperate fully with both the Bank and new service provider(s) to ensure there is a smooth transition. Further, the agreement shall ensure that the service provider is prohibited from erasing, purging, revoking, altering or changing any data during the transition period, unless specifically advised by the regulator/ concerned Bank.

11. Confidentiality and Security:

While availing outsourcing facility, it should be ensured that:

- Confidentiality and security of customer information should not be jeopardised.

- Only need-based access of customer information should be given to authorised staff of service provider.
- There is a system in place to monitor and review the security practices and control process of the service provider on a regular basis
- The service provider is able to isolate and clearly identify the bank's customer information, documents, records and assets to protect the confidentiality of the information

12. Review of the Policy:

All the guidelines are subject to get revised immediately on the basis of any fresh guidelines issued by RBI/NABARD/Sponsored Bank or any of such authorities. Chairman is empowered to incorporate/amend the guidelines of this policy. Hon'ble Board will be informed about the change in the subsequent meeting.

The policy will be reviewed at yearly intervals or as and when considered necessary by the Management/Board of Directors of the Bank.

The policy will be valid for one year from the date of approval or until next approval.

Appendix - I

Usage of Cloud Computing Services

There are several cloud deployment and service models that have emerged over time. These are generally based on the extent of technology stack that is proposed to be adopted by the consuming entity. Each of these models* come with corresponding service, business benefit and risk profiles.

In addition to the Outsourcing of IT Services controls prescribed in these Directions, Bank shall adopt the following requirements for storage, computing and movement of data in cloud environments:

1. While considering adoption of cloud solution, it is imperative to analyse the business strategy and goals adopted to the current IT applications footprint and associated costs**. Cloud adoption ranges from moving only non-business critical workloads to the cloud to moving critical business applications such as SaaS adoption and the several combinations in-between, which should be based on a business technology risk assessment.
2. In engaging cloud services, Bank shall ensure, inter alia, that the Outsourcing of IT Services policy addresses the entire lifecycle of data, i.e., covering the entire span of time from generation of the data, its entry into the cloud, till the data is permanently erased/ deleted. The Bank shall ensure that the procedures specified are consistent with business needs and legal and regulatory requirements.
3. In adoption of cloud services, the Bank shall take into account the cloud service specific factors, viz., multi-tenancy, multi-location storing/ processing of data, etc., and attendant risks, while establishing appropriate risk management framework. Cloud security is a shared responsibility between the Bank and the Cloud Service Provider (CSP). REs may refer to some of the cloud security best practices***, for implementing necessary controls, as per applicability of the shared responsibility model in the adoption of cloud services.

* For example, some cloud service and deployment models are: a) Infrastructure as a Service (IaaS): The service provides computer, storage, network, and other basic resources so that the client can develop and deploy their applications. b) Platform as a Service (PaaS): The service provides software for building application, middleware, database, development environment and other tools along with the infrastructure to the client. c) Software as a Service (SaaS): Client uses the application(s) provided by the service provider on a cloud infrastructure. d) Besides application services, Cloud Service Providers (CSPs) also provide a range of services besides the three common services viz. Database as a Service, Security as a Service, Storage as a Service and others with varying risk levels. Deployment Models: cloud services are delivered through popular models such as Private Cloud, Public Cloud, Hybrid Cloud, Community Cloud.

** For example, different heads of cloud related expenses could be application refactoring, integration, consulting, migration, projected recurring expenditure depending on the workloads, etc.

***i.) NIST SP 800-210 General Access Control Guidance for Cloud Systems -

<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-210.pdf>

ii) MeitY's cloud security best practices document -

https://www.meitv.gov.in/writereaddata/files/2.%20WI3_Cloud%20Security%20Best%20Practices_06112020.pdf

4. **Cloud Governance:** The Bank shall adopt and demonstrate a well-established and documented cloud adoption policy. Such a policy should, inter alia, identify the activities that can be moved to the cloud, enable and support protection of various stakeholder interests, ensure compliance with regulatory requirements, including those on privacy, security, data sovereignty, recoverability and data storage requirements, aligned with data classification.

The policy should provide for appropriate due diligence to manage and continually monitor the risks associated with CSPs.

5. Cloud Service Providers (CSP)

Considerations for selection of CSP: The Bank shall ensure that the selection of the CSP is based on a comprehensive risk assessment of the CSP. Bank shall enter into a contract only with CSPs subject to jurisdictions that uphold enforceability of agreements and the rights available thereunder to Bank, including those relating to aspects such as data storage, data protection and confidentiality.

6. Cloud Services Management and Security Considerations

- a) **Service and Technology Architecture:** The Bank shall ensure that the service and technology architecture supporting cloud-based applications is built in adherence to globally recognised architecture principles and standards. Bank shall prefer a technology architecture that provides for secure container-based data management, where encryption keys and Hardware Security Modules are under the control of the Bank. The architecture should provide for a standard set of tools and processes to manage containers, images and releases. Multi-tenancy environments should be protected against data integrity and confidentiality risks, and against co-mingling of data. The architecture should be resilient and enable smooth recovery in case of failure of any one or combination of components across the cloud architecture with minimal impact on data/ information security.
- b) **Identity and Access Management (IAM):** IAM shall be agreed upon with the CSP and ensured for providing role-based access to the cloud hosted applications, in respect of user-access and privileged-access. Stringent access controls, as applicable for an on-premises application, may be established for identity and access management to cloud-based applications. Segregation of duties and role conflict matrix should be implemented for all kinds of user-access and privileged-access roles in the cloud-hosted application irrespective of the cloud service model. Access provisioning should be governed by principles of 'need to know' and 'least privileges'. In addition, multi-factor authentication should be implemented for access to cloud applications.
- c) **Security Controls:** Bank shall ensure that the implementation of security controls in the cloud-based application achieves similar or higher degree of control objectives than those achieved in/ by an on-premises application. This includes ensuring - secure connection through appropriate deployment of network security resources and their configurations; appropriate and secure configurations, monitoring of the cloud assets utilised by the Bank; necessary procedures to authorise changes to cloud applications and related resources.
- d) **Robust Monitoring and Surveillance:** Bank shall accurately define minimum monitoring requirements in the cloud environment. Bank will ensure to assess the information/ cyber security capability of the cloud service provider, such that, the
 - i) CSP maintains an information security policy framework commensurate with its exposures to vulnerabilities and threats;
 - ii) CSP is able to maintain its information/ cyber security capability with respect to changes in vulnerabilities and threats, including those resulting from changes to information assets or its business environment;
 - iii) nature and frequency of testing of controls by the CSP in respect of the outsourced services is commensurate with the materiality of the services being outsourced by the Bank and the threat environment; and CSP has mechanisms in place to assess the sub-

contractors with regards to confidentiality, integrity and availability of the data being shared with the sub-contractors, where applicable.

- e) Appropriate integration of logs, events from the CSP into the Bank SOC, wherever applicable and/ or retention of relevant logs in cloud shall be ensured for incident reporting and handling of incidents relating to services deployed on the cloud.
- f) The Bank own efforts in securing its application shall be complemented by the CSP's cyber resilience controls. The CSP / Bank shall ensure continuous and regular updates of security-related software including upgrades, fixes, patches and service packs for protecting the application from advanced threats/ malware.
- g) **Vulnerability Management:** Bank shall ensure that CSPs have a well-governed and structured approach to manage threats and vulnerabilities supported by requisite industry-specific threat intelligence capabilities.

7. Disaster Recovery & Cyber Resilience

- a) The Bank's business continuity framework shall ensure that, in the event of a disaster affecting its cloud services or failure of the CSP, the Bank can continue its critical operations with minimal disruption of services while ensuring integrity and security.
 - b) Bank shall ensure that the CSP puts in place demonstrative capabilities for preparedness and readiness for cyber resilience as regards cloud services in use by them. This should be systematically ensured, inter alia, through robust incident response and recovery practices including conduct of Disaster Recovery (DR) drills at various levels of cloud services including necessary stakeholders.
 - c) Under the segment Business Continuity Plan and Disaster Recovery Plan of service provider, information about RPO (Recovery Point Objective) and RTO (Recovery Time Objective (RTO) should be mentioned if it relates to the outsourced services.
8. The following points may be evaluated while developing an exit strategy:
- a) the exit strategy and service level stipulations in the SLA shall factor in, inter alia,
 - i) agreed processes and turnaround times for returning the Bank's service collaterals and data held by the CSP;
 - ii) data completeness and portability;
 - iii) secure purge of RE's information from the CSP's environment;
 - iv) smooth transition of services; and
 - v) unambiguous definition of liabilities, damages, penalties and indemnities.
 - b) monitoring the ongoing design of applications and service delivery technology stack that the exit plans should align with.
 - c) contractually agreed exit / termination plans should specify how the cloud- hosted service(s) and data will be moved out from the cloud with minimal impact on continuity of the Bank's business, while maintaining integrity and security.
 - d) All records of transactions, customer and operational information, configuration data should be promptly taken over in a systematic manner from the CSP and purged at the CSP-end and independent assurance sought before signing off from the CSP.
9. **Audit and Assurance:** The audit/ periodic review/ third-party certifications should cover, as per applicability and cloud usage, inter alia, aspects such as roles and responsibilities of both Bank and CSP in cloud governance, access and network controls, configurations, monitoring mechanism, data encryption, log review, change management, incident response, and resilience preparedness and testing, etc.

Handwritten signature/initials

Appendix - II

Outsourcing of Security Operations Centre

Outsourcing of Security Operations Centre (SOC) operations has the risk of data being stored and processed at an external location and managed by a third party (Managed Security Service Provider (MSSP)) to which Bank has lesser visibility. To mitigate the risks, in addition to the controls prescribed in these Directions, Bank shall adopt the following requirements in the case of outsourcing of SOC operations:

- a) unambiguously identify the owner of assets used in providing the services (systems, software, source code, processes, concepts, etc.);
- b) ensure that the Bank has adequate oversight and ownership over the rule definition, customisation and related data/ logs, meta-data and analytics (specific to the Bank);
- c) assess SOC functioning, including all physical facilities involved in service delivery, such as the SOC and areas where client data is stored / processed periodically;
- d) integrate the outsourced SOC reporting and escalation process with the Bank's incident response process; and
- e) review the process of handling of the alerts / events.
